

INSTITUTO INFNET
ESCOLA SUPERIOR DE TECNOLOGIA
GRADUAÇÃO EM ENGENHARIA DE
SOFTWARE



Turma - GRLENGR2C1-N2-L1
Curso - Desenvolvimento Seguro de
Aplicações Web
Professor - Fabiano Domingues

AT

Alunos: Ademir de Lucca Junior.

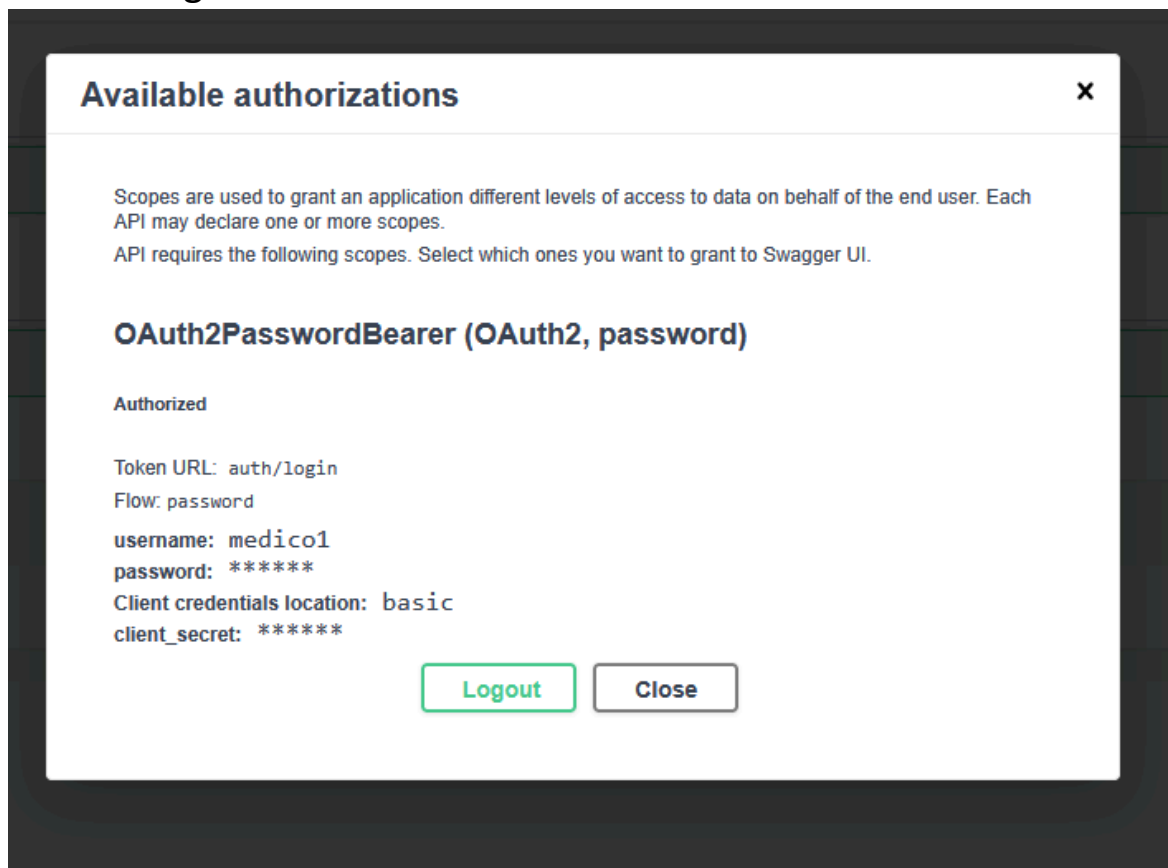
3 de out. de 2026

Exercícios

Github:

<https://github.com/yADMh/Desenvolvimento-Seguro-de-Aplicacao-Web>

Print do login



pytest

```
(venv) PS C:\Python\eventos-api-final2\eventos-api> python -m pytest -v
===== test session starts =====
platform win32 -- Python 3.11.9, pytest-8.1.1, pluggy-1.6.0 -- C:\Python\eventos-api-final2\eventos-api\venv\Scripts\python.exe
cachedir: .pytest_cache
rootdir: C:\Python\eventos-api-final2\eventos-api
plugins: anyio-4.15.1
collected 7 items

tests/test_consultas.py::test_stored_xss_mitigation PASSED [ 14%]
tests/test_consultas.py::test_200_com_ownership PASSED [ 28%]
tests/test_consultas.py::test_403_sem_ownership_bola PASSED [ 42%]
tests/test_consultas.py::test_403_scope_insuficiente PASSED [ 57%]
tests/test_consultas.py::test_422_payload_invalid_extra_forbid PASSED [ 71%]
tests/test_seguranca.py::test_401_sem_token PASSED [ 85%]
tests/test_seguranca.py::test_rate_limiting PASSED [100%]

===== warnings summary =====
venv\Lib\site-packages\starlette\testclient.py:41
C:\Python\eventos-api-final2\eventos-api\venv\Lib\site-packages\starlette\testclient.py:41: DeprecationWarning: The anyio.abc.BlockingPortal alias is deprecated, use anyio.from_thread.BlockingPortal instead.
  [], typing.ContextManager[anyio.abc.BlockingPortal]

tests/test_consultas.py::test_stored_xss_mitigation
tests/test_consultas.py::test_200_com_ownership
tests/test_consultas.py::test_403_sem_ownership_bola
tests/test_consultas.py::test_403_scope_insuficiente
tests/test_consultas.py::test_422_payload_invalid_extra_forbid
tests/test_seguranca.py::test_401_sem_token
tests/test_seguranca.py::test_rate_limiting
C:\Python\eventos-api-final2\eventos-api\venv\Lib\site-packages\httpx_client.py:680: DeprecationWarning: The 'app' shortcut is now deprecated. Use the explicit style 'transport=HTTPTransport(app=...)' instead.
  warnings.warn(message, DeprecationWarning)

tests/test_consultas.py::test_stored_xss_mitigation
C:\Python\eventos-api-final2\eventos-api\venv\Lib\site-packages\starlette\templating.py:178: DeprecationWarning: The 'name' is not the first parameter anymore. The first parameter should be the 'Request' instance.
  Replace 'TemplateResponse(name, {"request": request})' by 'TemplateResponse(request, name)'.
  warnings.warn(

-- Docs: https://docs.pytest.org/en/stable/how-to/capture-warnings.html
===== 7 passed, 9 warnings in 0.18s =====
(venv) PS C:\Python\eventos-api-final2\eventos-api>
```

print da tela de login para colocar os campos

Available authorizations

password:

Client credentials location:

Authorization header

client_id:

client_secret:

Scopes: [select all](#) [select none](#)

☒

read:consultas

Ler consultas

☒

write:consultas

Criar consultas

☐

role:admin

Privilegios administrativos

Authorize

Close

post consulta funcionando

Consultas

POST /consultas/ Criar Consulta

Parameters

No parameters

Request body required

application/json

Edit Value | Schema

```
{
  "paciente_id": 1,
  "profissional_id": 1,
  "data_horario": "2026-09-21T23:34:16.024Z",
  "especialidade": "string"
}
```

Execute

Clear

Responses

Curl

```
curl -X 'POST' \
  'http://127.0.0.1:8000/consultas/' \
  -H 'accept: */*' \
  -H 'Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ2ZmI0Ij7Zs@pY29fdGVzdGUlCjY29uc3VsZGFzOnJlYWQlICJjb25zdG90YXNpd3pdGllKSXNlbnR5X3ZlcnVlC3JleHAlOjE3OTAwMzUzNjR9.GG' \
  -H 'Content-Type: application/json' \
  -d '{
    "paciente_id": 1,
    "profissional_id": 1,
    "data_horario": "2026-09-21T23:34:16.024Z",
    "especialidade": "string"
  }'
```

Request URL

http://127.0.0.1:8000/consultas/

Server response

Code	Details
200	Response body <pre>{ "id": 59, "paciente_id": 1, "profissional_id": 1, "data_horario": "2026-09-21T23:34:16.024000", "especialidade": "string", "status": "agendada" }</pre>

get consulta funcionando

client_secret
string

☒ Send empty value

username
string

☐ Send empty value

password
string

☐ Send empty value

scope
string

☒ Send empty value

Execute

Clear

Responses

Curl

```
curl -X 'POST' \
  'http://localhost:8080/auth/login' \
  -H 'accept: application/json' \
  -H 'Content-Type: application/x-www-form-urlencoded' \
  -d 'grant_type=password&client_id=&client_secret=&username=admin&password=123&scope='
```

Request URL

```
http://localhost:8080/auth/login
```

Server response

Code	Details
401 Undocumented	Error: Unauthorized Response body <pre>{ "detail": "MFA required" }</pre> Response headers <pre>access-control-allow-credentials: true content-length: 25 content-type: application/json date: Sat, 03 Oct 2020 20:28:34 GMT server: uvicorn strict-transport-security: max-age=31536000; includeSubDomains x-content-type-options: nosniff x-frame-options: DENY</pre>

Responses

Code	Description	Link
------	-------------	------

ERRO 422

^

Consultas

- Data: 2026-10-03 20:29:43.020000 - Especialidade: Cardiologia - Obs: string
- Data: 2026-10-12 09:00:00 - Especialidade: Clínica Geral - Obs: <script>alert('FALHA GRAVE XSS!')</script>

get consultado com erro(BOLA)

GET /consultas/{consulta_id} Ler Consulta

Parameters

Cancel

Name	Description
consulta_id * required	
integer	1
(path)	

Execute

Clear

Responses

Curl

```
curl -X 'GET' \
  'http://localhost:8000/consultas/1' \
  -H 'accept: application/json' \
  -H 'Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiJ3YWRpZm50ZTE1LlCj2C16Mylicm9uZSI6Imh5Z11ibm81Iiwic2NvcGVzIjpbIn1lYXQ6Y29uc3VudGFz118sInV4cCI6MTc5MTA2MTgzOj09. qWubgm5fyG0S2z70y
```

Request URL

http://localhost:8000/consultas/1

Server response

Code	Details
403	Error: Forbidden

Response body

```
{
  "detail": "Acesso a prontuario de terceiros bloqueado"
}
```

Download

Response headers

```
content-length: 55
content-type: application/json
date: Sat, 03 Oct 2020 20:40:45 GMT
server: uvicorn
strict-transport-security: max-age=31536000; includeSubDomains
x-content-type-options: nosniff
x-frame-options: DENY
```

Responses

Code	Description	Links
200	Successful Response	No links

Media type

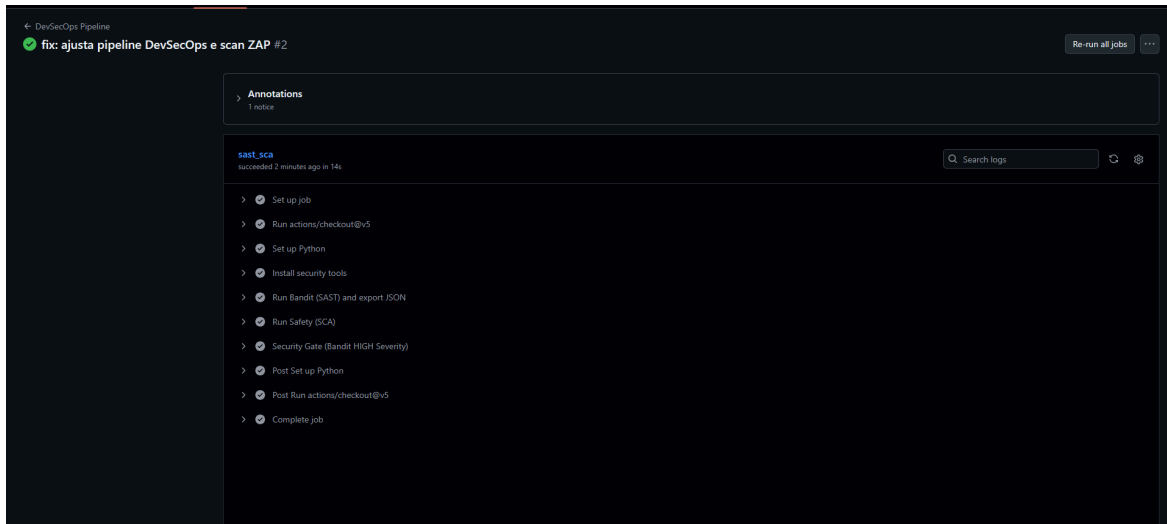
application/json

Controls Accept header.

Example Value | Schema

agenda

10



DAST e Zap Github

